

Argumentaire solutions concretes - Yvan

Argumentaire solutions concretes - Yvan FOCSA

Objectif

Ce document transforme les notions generales de ma partie en choix techniques concrets et defendables. L'objectif est de pouvoir repondre au jury sans rester au niveau "concept".

Synthese orale en 30 secondes

Notre architecture n'est pas juste theorique. Le SOC central repose sur Wazuh : Manager, Indexer/OpenSearch et Dashboard. Les postes et serveurs utilisent des agents Wazuh, les firewalls sont modelises avec pfSense CE et export syslog, les applications metier produisent des logs JSONL, et la messagerie est simulee via des logs mail. Le MVP utilise 3 sites representatifs, mais l'industrialisation repose sur un inventaire site, une convention de nommage, une checklist d'onboarding, des flux reseau filtres et des dashboards filtrables par site.

Tableau des choix concrets

Concept a defendre	Solution concrete retenue	Pourquoi ce choix est coherent	Preuve / fichier
SOC externalise	Plateforme SOC cote prestataire SOC-EXTERNALISE-01 avec Wazuh Manager, Wazuh Indexer/OpenSearch et Wazuh Dashboard	Le client n'a pas les ressources internes pour exploiter un SOC ; la centralisation permet de mutualiser supervision, regles, playbooks et reporting	etape_1/docs/02_Dossier_Architecture_Technique.md
SIEM open-source	Wazuh	Couvre collecte agent, regles, alertes, dashboard web et integration logs ; pas de cout licence pour le MVP	scripts/setup-siem-lab.ps1, livrables/youssef/README_YOUSSEF.md
Indexation / recherche	Wazuh Indexer base sur OpenSearch	Necessaire pour rechercher les alertes, historiser les evenements et alimenter les dashboards	Architecture Wazuh, rapport final
Interface web	Wazuh Dashboard en HTTPS	Repond a l'exigence d'interface accessible navigateur ; permet vues supervision, analyste et admin	Captures dashboard et scripts/setup-siem-lab.ps1
Postes de travail	Agents Wazuh sur PC-S01-AUDIO-01, PC-S02-AUDIO-01, PC-S03-AUDIO-01	Les agents collectent authentications, executions suspectes, USB et evenements systeme	Inventaire site_inventory.example.yml, alertes 100100, 100140
Logs Windows avances	Sysmon en cible production	Wazuh agent suffit au MVP ; Sysmon renforcerait la detection processus, PowerShell, persistence et activite fichier en production	Mention en perspective technique
Serveurs internes	SRV-S01-FICHIERS et conteneur serveur-01 avec agent Wazuh et /var/log/auth.log	Reproduit la logique serveur interne, authentication, fichiers et privilege escalation sans monter un vrai AD complet	scripts/setup-siem-lab.ps1, alerte 100130
Active Directory	AD simule par logs ad_events.jsonl et scenario groupe privilegie	Un vrai AD demande plus de temps ; le MVP prouve le cas de detection avec logs realistes et playbook associe	etape_1/logs/generated/ad_events.jsonl, regle 100130
Firewall / routeur	pfSense CE cible ; FW-S01 et FW-S02 dans le MVP	pfSense est open-source, connu, compatible syslog ; si le client a Fortigate/Stormshield/Sophos, le meme principe syslog reste valable	07_stack_technique_concrete_yvan.md, firewall_syslog.log
Syslog firewall	Export syslog pfSense vers Wazuh Manager, port 514 en lab, 5514 ou VPN en production	Syslog est le standard pour logs reseau/firewall ; le filtrage IP evite d'accepter des sources non autorisees	Guide deploiement, inventaire site

Concept a defendre	Solution concrete retenue	Pourquoi ce choix est coherent	Preuve / fichier
Applications metier	APP-S01-CRM et APP-S03-LOGS, logs JSONL application_events.jsonl	Permet de couvrir CRM/RDV/dossiers patients sans manipuler de vraies donnees patients	Alerte 100120, logs applicatifs
Messagerie	MAIL-S02, logs JSONL mail_events.jsonl	Permet de prouver le scenario phishing sans deployer Exchange/Zimbra complet	Alerte 100150, playbook phishing
Detection reseau	Regles Wazuh sur logs firewall ; Suricata en option production	Les regles firewall suffisent au MVP ; Suricata ajouterait IDS reseau si le client veut une detection plus riche	Regle 100160, playbook scan reseau
RBAC	Comptes analyste et supervision avec role soc_readonly	Montre une separation concrete des droits ; evite que tous les utilisateurs aient les droits admin	scripts/setup-siem-lab.ps1
Flux inter-sites	VPN site-a-site ou filtrage reseau strict en production	Les logs viennent de 30 sites : il faut eviter d'exposer Wazuh directement sur Internet	Section flux techniques
Retention logs	Courte en MVP ; politique cible 30/90/180 jours selon besoin client	Le stockage depend du volume de logs et de la duree de conservation ; c'est un cout production majeur	etape 1/docs/04_Gestion_Couts.md
Sauvegardes	Sauvegarde configuration Wazuh, regles, scripts, playbooks et exports	Permet de reconstruire le SOC et de conserver la preuve documentaire	Perspectives production
Dashboards par role	Vues supervision, analyste SOC, admin, direction/client	Chaque profil ne cherche pas la meme information : etat global, detail alerte, configuration, reporting	etape 1/dashboard/dashboar d_spec.md
Playbooks	Playbooks Markdown PB-001 a PB-006	Reponse semi-automatisee : qualification, verification, action, preuve et REX	etape 1/playbooks/
Reporting	Rapport PDF, matrice de conformite, REX incidents, exports dashboard	Repond au besoin d'un SOC externalise : rendre compte au client, pas seulement detecter	livrables/rapport-final/, rex-incidents-simules.md
Industrialisation	Inventaire YAML, checklist onboarding, convention SITE-XX, PC-SXX, FW-SXX	Permet de repeter le deploiement vers 30 centres sans refaire une architecture a la main	site_inventory.example.yml, client_onboarding_checklis t.md
Gestion des couts	Open-source pour le logiciel ; couts reels = infra, stockage, exploitation SOC, onboarding	Explique pourquoi le MVP est economique mais pourquoi la production a quand meme un budget	etape 1/docs/04_Gestion_Couts.md

Arguments par grande question jury

Pourquoi Wazuh et pas Splunk / QRadar ?

Wazuh est coherent pour un projet M2 et un reseau de centres de taille moyenne car il est open-source, deployable rapidement, compatible agents et syslog, et dispose deja d'une interface web. Splunk ou QRadar seraient credibles en production enterprise, mais ils ajoutent un cout licence et une complexite qui ne sont pas necessaires pour prouver le MVP.

Phrase a dire :

Nous avons retenu Wazuh car il couvre les besoins du cahier des charges avec un cout logiciel nul pour le MVP : collecte multi-source, regles, alertes, dashboard web et deploiement reproductible.

Pourquoi 3 sites et pas les 30 ?

Le besoin cible est bien 30 centres. Le MVP ne doit pas recopier 30 fois le meme schema : il doit prouver une chaine complete et montrer comment elle se repete. Les 3 sites representent les variantes utiles : site complet, site secondaire, site leger.

Phrase a dire :

Les 30 centres sont le perimetre client cible. Les 3 sites sont le perimetre MVP : ils prouvent le modele, puis l'inventaire et la checklist permettent de le repeter.

Pourquoi simuler certains logs ?

Le sujet demande un démonstrateur fonctionnel, pas une production avec données patients réelles. Simuler les logs permet de contrôler la démonstration, d'éviter les données sensibles et de produire des scénarios reproductibles.

Phrase à dire :

Les logs simulés ne remplacent pas une production, mais ils prouvent les chemins de détection sans exposer de données sensibles.

Pourquoi pfSense pour le firewall ?

pfSense CE est open-source, documenté et capable d'exporter du syslog. Il est donc cohérent avec la logique open-source du projet. Mais l'architecture n'est pas enfermée dans pfSense : Fortigate, Stormshield, Sophos ou Cisco fonctionnent aussi si le client les possède, tant qu'ils exportent les logs vers le SOC.

Pourquoi Sysmon est seulement optionnel ?

Sysmon est très utile pour enrichir les logs Windows, mais le MVP peut déjà prouver la collecte endpoint avec Wazuh agent. En production, Sysmon serait recommandé pour mieux détecter PowerShell, processus suspects et persistance.

Pourquoi Suricata est seulement optionnel ?

Suricata apporte une vraie brique IDS réseau, mais le cahier des charges demande d'abord un SIEM, de la collecte multi-source, des alertes, dashboards et playbooks. Le MVP couvre déjà la partie réseau avec les logs pfSense/syslog. Suricata serait une évolution si l'on veut analyser le trafic plus finement.

Pourquoi Shuffle ou TheHive ne sont pas obligatoires ?

Le cahier des charges parle de playbooks semi-automatisés. Les playbooks Markdown suffisent à prouver la méthode SOC : qualifier, vérifier, agir, documenter. TheHive ajouterait du ticketing et Shuffle de l'orchestration, mais ce sont des évolutions production, pas des pré-requis pour le MVP.

Comment sécuriser les flux ?

En production, les sites n'enverraient pas leurs logs à un SIEM exposé publiquement. Les flux seraient limités par VPN site-a-site, filtrage IP, ports stricts, comptes nominatifs, RBAC et supervision de l'état des agents.

Phrases courtes à mémoriser

- "Le SOC central est concret : Wazuh Manager, Indexer/OpenSearch et Dashboard."
- "Les postes et serveurs remontent par agent Wazuh ; les firewalls pfSense remontent par syslog ; les applications et la messagerie remontent par logs JSONL dans le MVP."
- "Les 3 sites ne remplacent pas les 30 centres : ils prouvent le modèle industrialisable."
- "La partie production a surtout besoin de VPN, filtrage IP, rétention, sauvegardes, supervision de santé et dimensionnement stockage."
- "Nous assumons les simulations : elles rendent la démo stable, reproductible et sans données patients réelles."
- "Les outils optionnels comme Suricata, TheHive ou Shuffle sont des évolutions, pas des dépendances du MVP."